

ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Attacks to the Supply Chains

Michele Colajanni

Dipartimento di Informatica – Scienza e Ingegneria

michele.colajanni@unibo.it

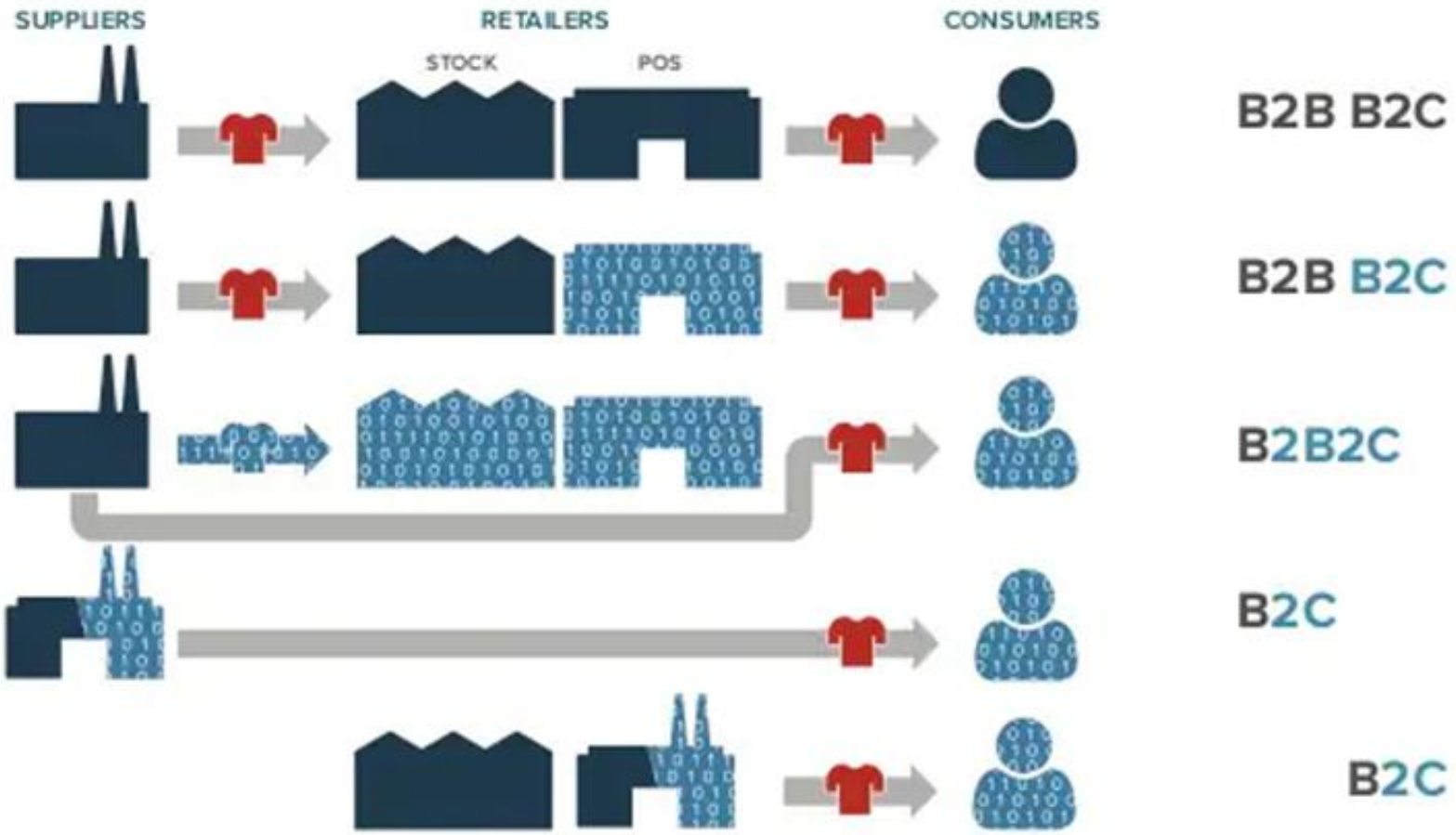
Supply chain

A **supply chain** is a system of organizations, people, technology, activities, information and physical resources involved in moving a product or a service from a supplier (*producer*) to a customer (*consumer*)

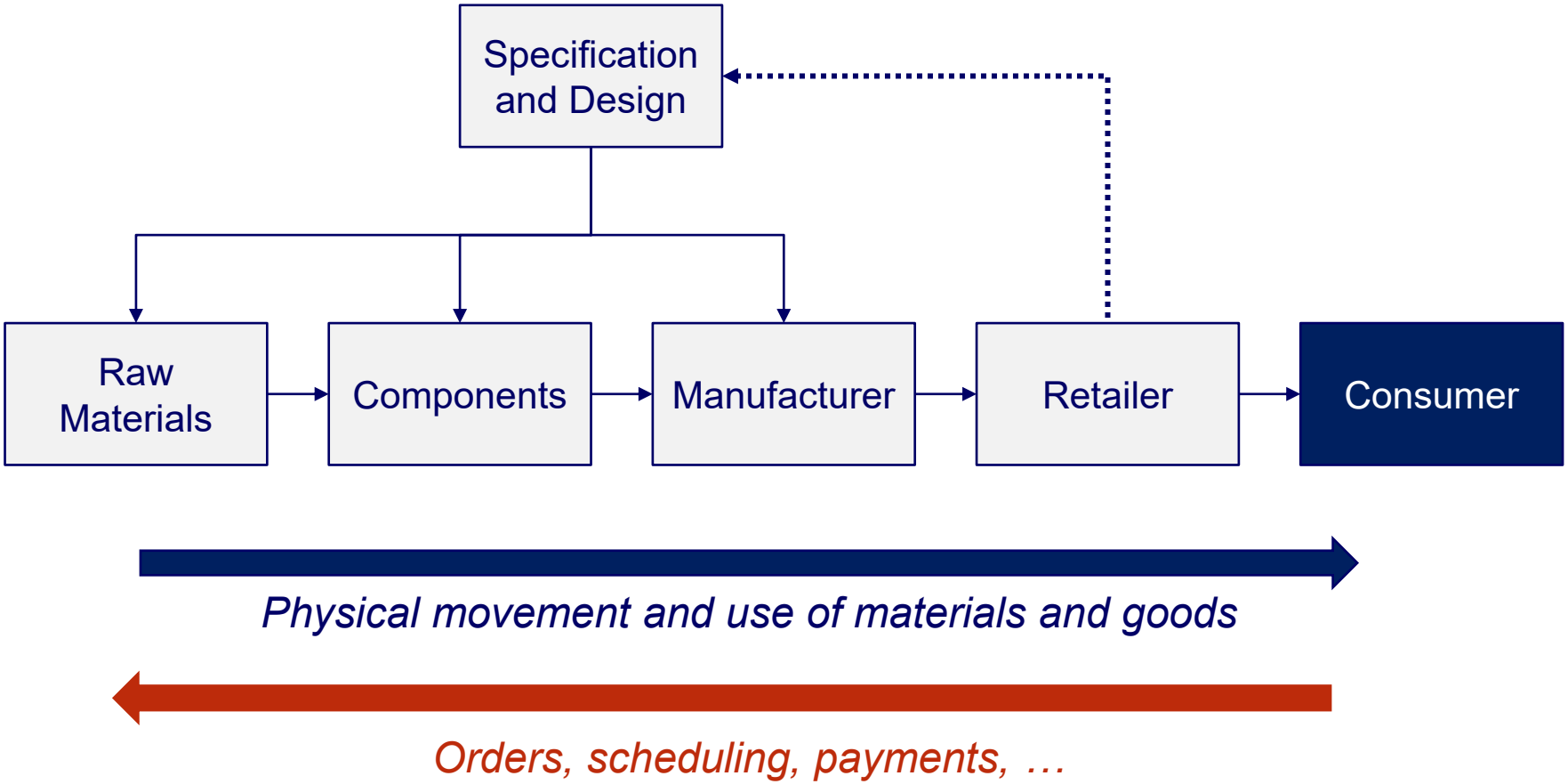
Virtually any **modern production, service and business process in the age of digital society** requires collaboration through some type of digital information, digital communication and/or shared digital services



All companies are part of a supply chain

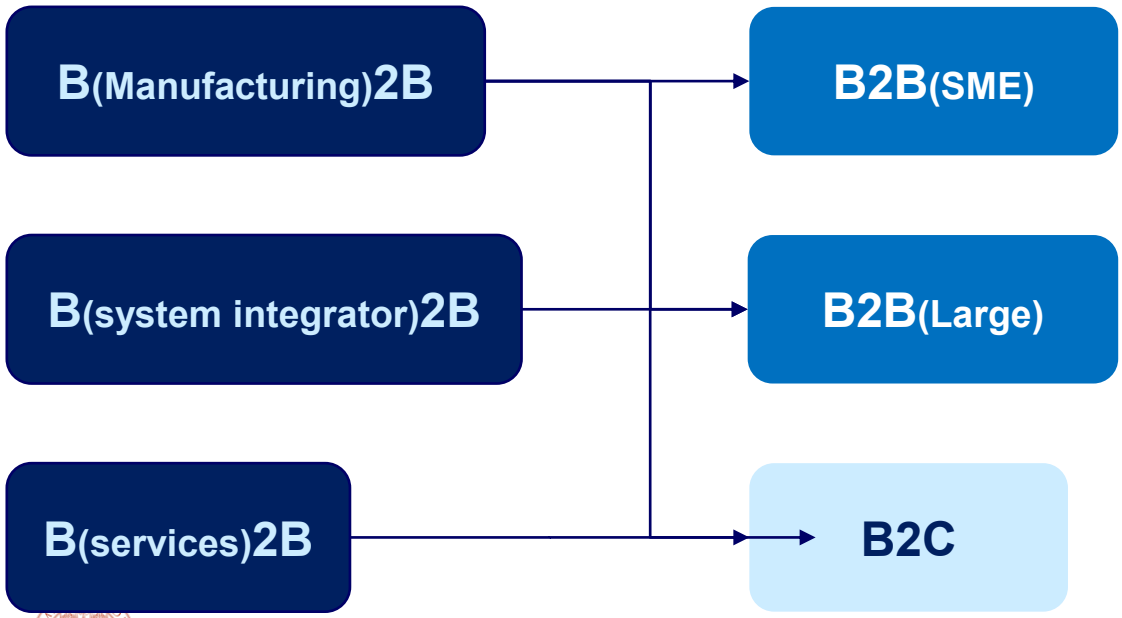


The traditional supply chain is linear and refers to physical materials



“Where is my organization?”
“To which supply chain does my industry belong?”

	Agricolture	Metal	Chemical	Commerce	Construction	Education	Financial	…
SME								
Medium								
Large								
Public								



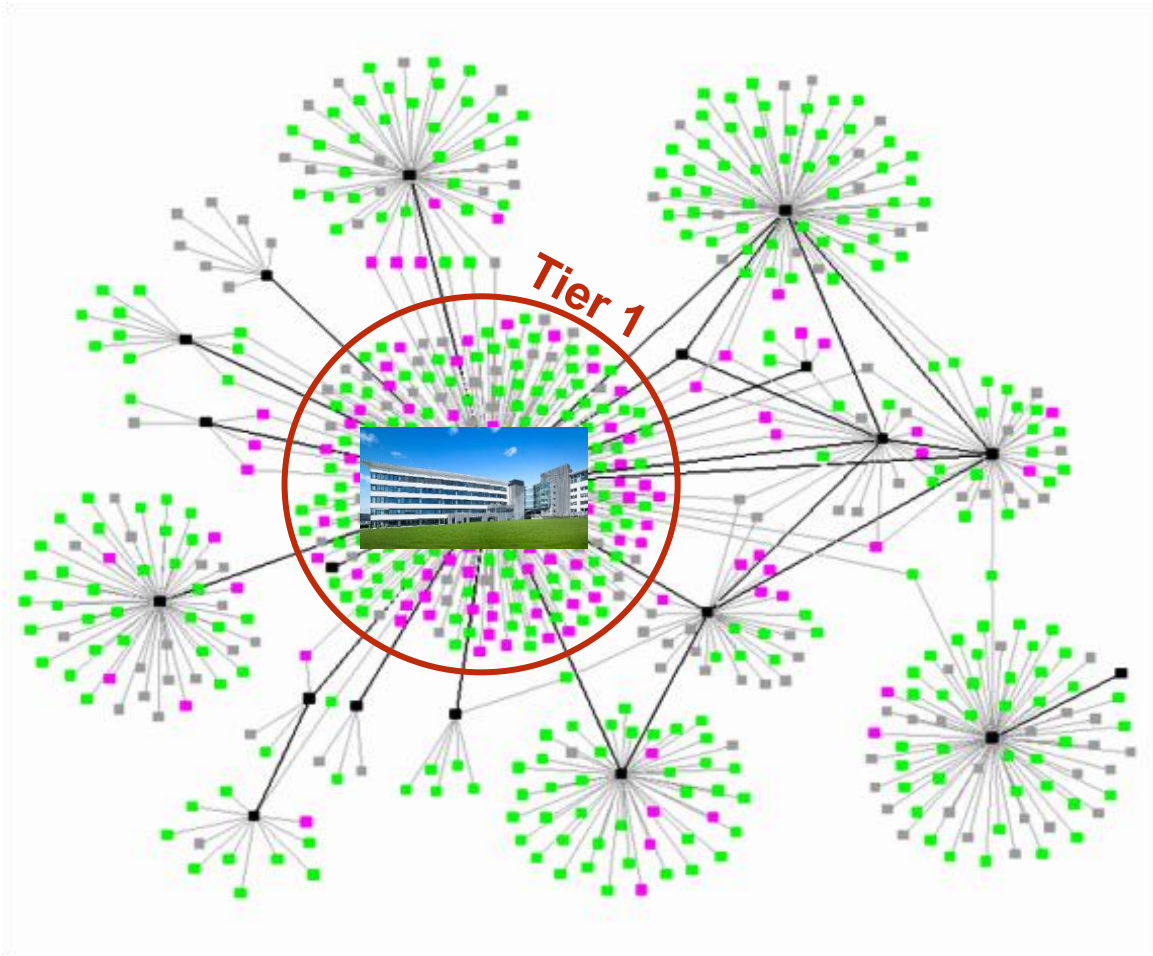
IT support and integrators
Cybersecurity
Software devs & integrators
Consultancy
Marketing companies
…

Moreover, there are several types of human suppliers

- Technical engineers, integrators
- Maintainers
- Repairers
- Vendors
- Consultants
- Lawyer, Notary, Accountant
- Corporate doctors
- …



The ecosystem of a modern company



Fractal vision:
it exhibits similar patterns at different scales as in the Mandelbrot set → *self-similarity property*

Classes of vulnerabilities [*Defense Science Board Report*]

Three classes:

- **Tier 1**: Known vulnerabilities
- **Tier 2**: Unknown vulnerabilities (e.g., allowing zero-day exploits)
- **Tier 3**: Adversary-created vulnerabilities (e.g., created by APTs)

The main problem with supply chains is that a significant number of vulnerabilities are "off the radar" of an organization



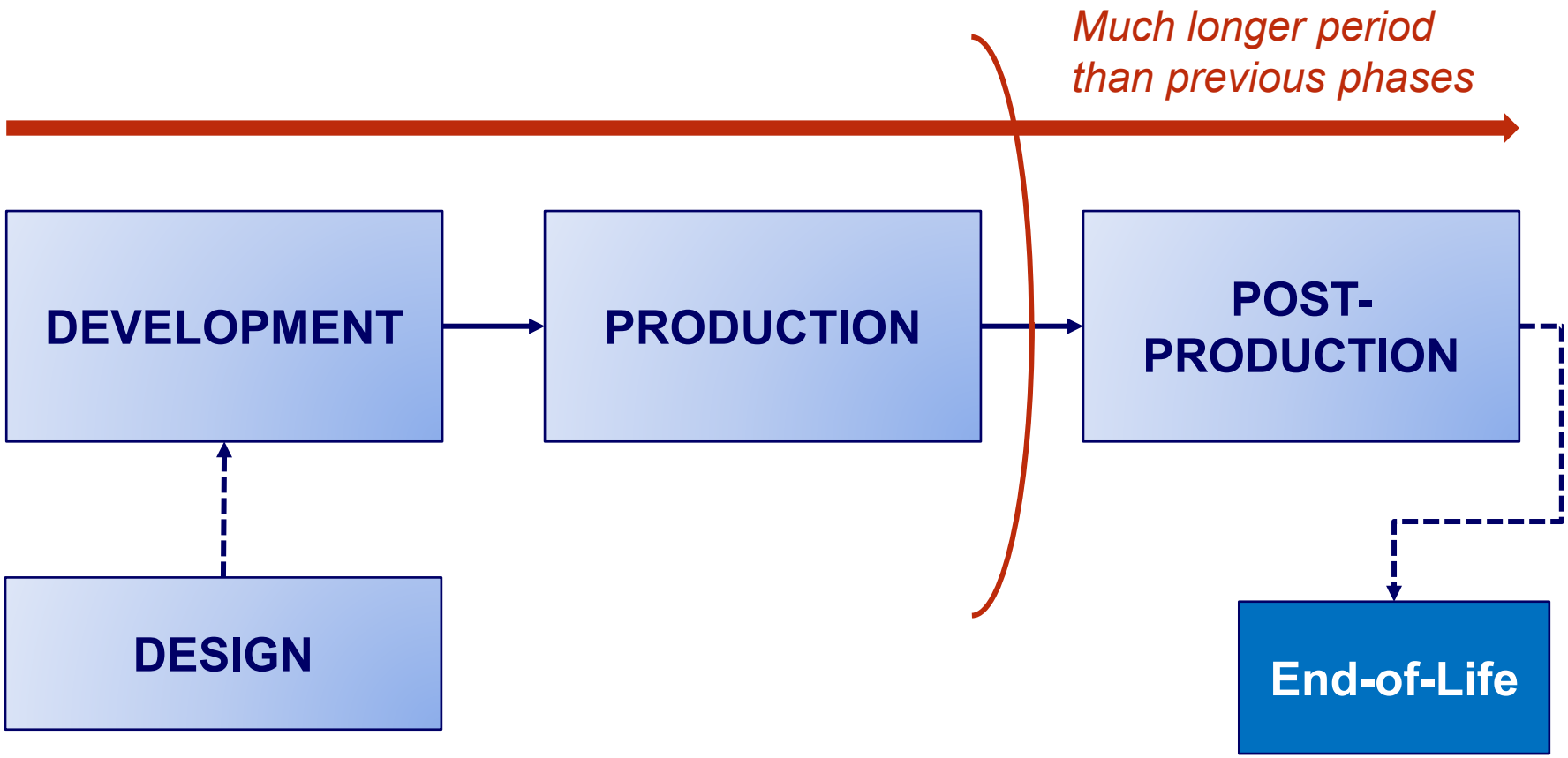
Two types of supply chain problems

1. **Poor management design**

2. **Poor operations**



Any product has a *life*: vulnerabilities may occur always



Design vulnerabilities: *national* and *international*

1) **National level**. Within the supply chain ecosystem, **norms**, **standards** and **policies** *should* represent the highest level, often serving as conceptual frameworks for other elements:
   - Agreement regulations
   - Guidelines
   - Operational procedures

2) **International level**. Lack of standardized process frameworks for dealing with global technology vendors in international markets



Typical cybersecurity vulnerabilities still exist

A supply chain includes

- Hardware (PC, server machines, devices)
- Local storage
- Network components

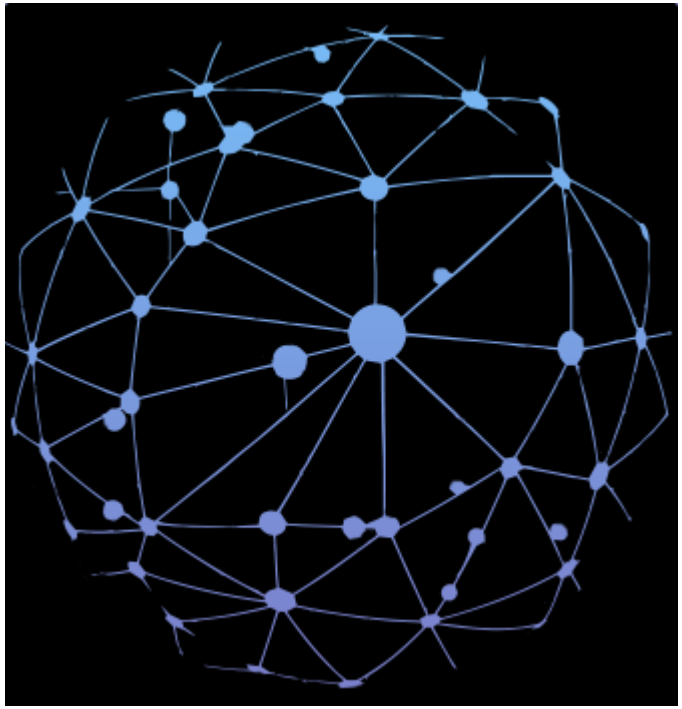
- Operating systems
- Software
- Cloud

- Distribution mechanisms
- People: consultants, maintainers, temporary workers
- …



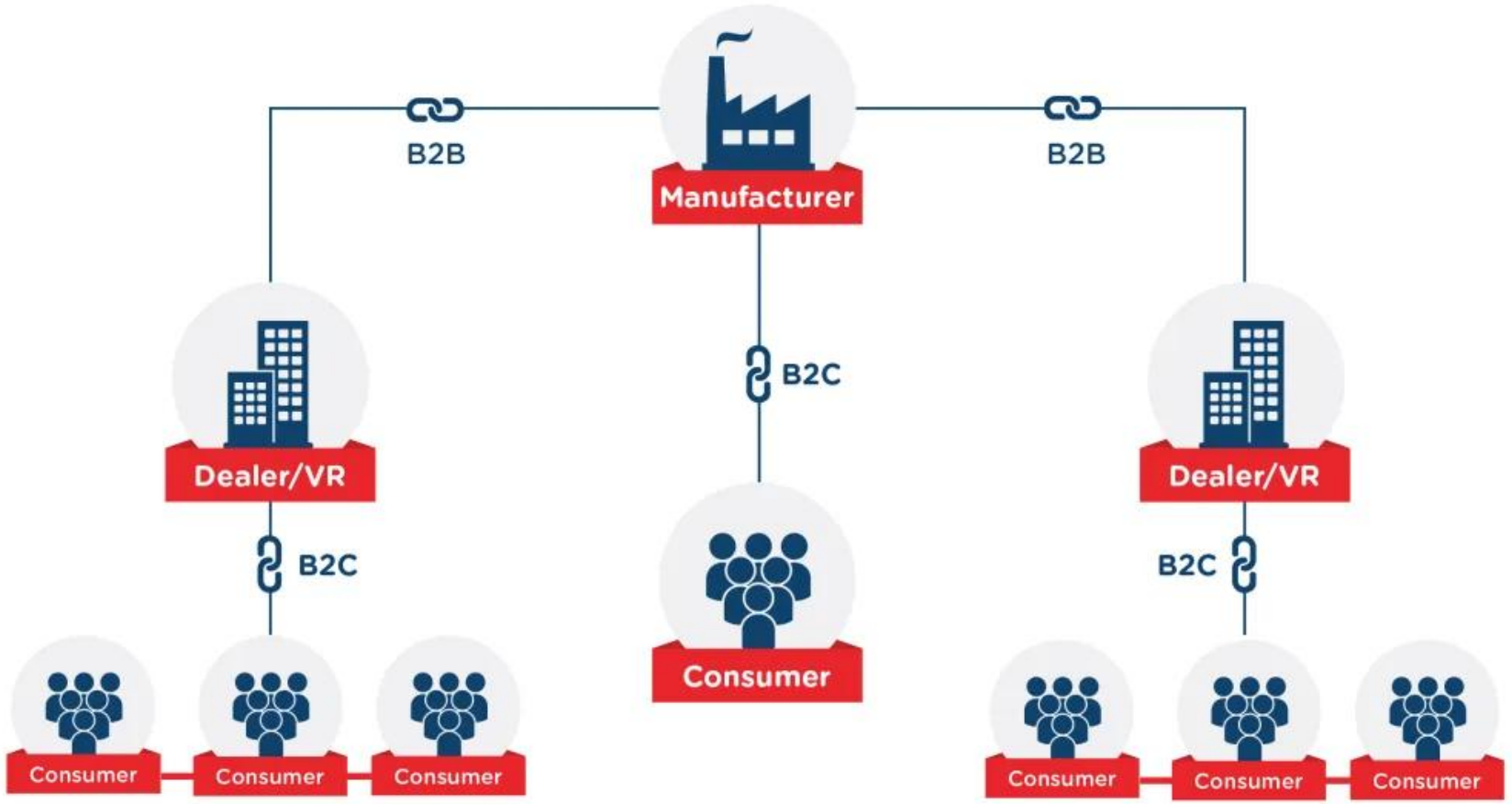
Assessing the potential of organizations through network analysis



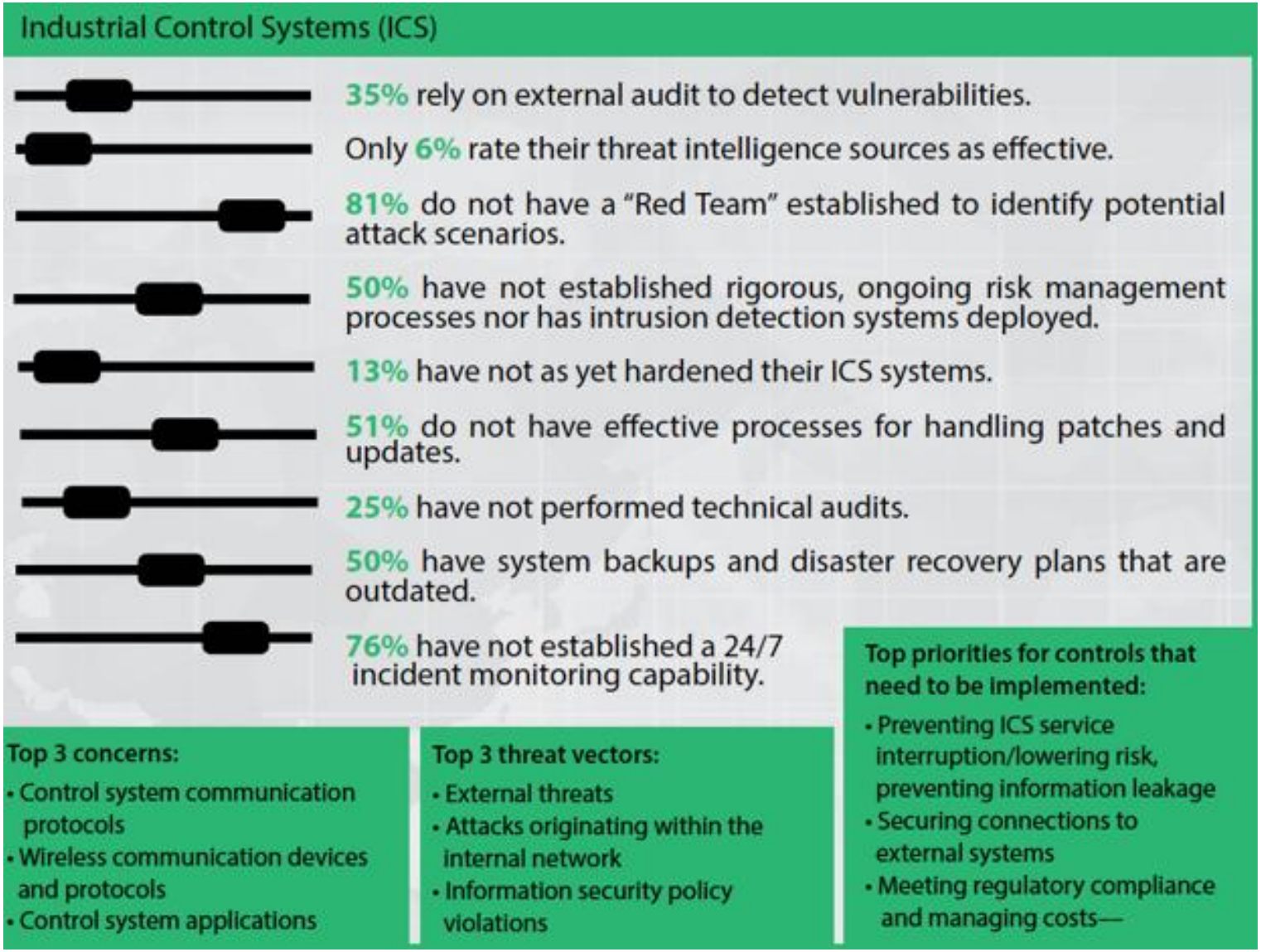


Typical scenario

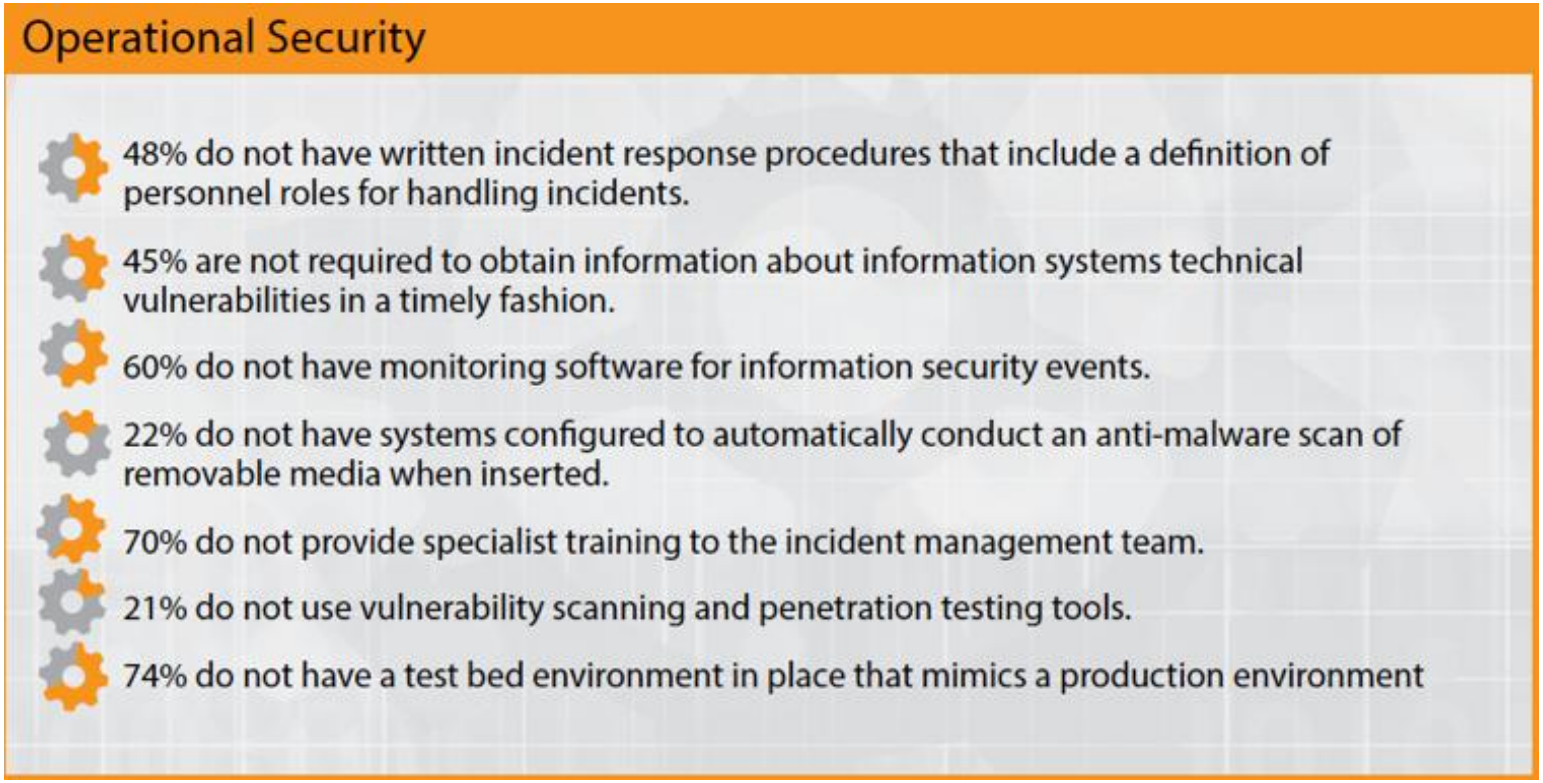




160 vulnerabilities were reviewed across the organization's domain of industries



Vulnerabilities related to lack of *incident management*



For **66%** of the supply chain attacks analyzed, **suppliers did not know**, **or failed to report on how they were compromised.**

However, less than **9%** of the customers compromised through supply chain attacks did not know how the attacks occurred. **This highlights the gap in terms of maturity in cybersecurity incident reporting between suppliers and end-users**

Typical lacks of management by the *customers* (leading to vulnerabilities)

- Not **identifying** and not documenting their suppliers and service providers
- Not defining **risk criteria for different types of suppliers** and services, such as supplier and customer dependencies, critical software dependencies, single points of failure
- Not **monitoring** supply chain risks and threats
- Not **managing** suppliers over the whole lifecycle of a product or service, including procedures to handle end-of-life of products and/or components
- Not **defining robust and controlled procedures** for accessing and handling organization's assets and resources



Typical lack of management by the *suppliers* (leading to vulnerabilities)

- Not investing on **people** awareness and competence
- Not investing in achieving cybersecure mature **processes** through some standards
- Not ensuring that the infrastructure used to design, develop, manufacture, and deliver products, components and services follows **cybersecurity practices**
- Not implementing a product development, maintenance and support process that is consistent with commonly accepted cybersecure product development **processes**
- Not monitoring cybersecurity **vulnerabilities** reported by internal and external sources that includes used third-party components
- Not maintaining an **inventory** of assets that includes patch-relevant information



Supply chains in the digital world



An old message still valid

Supply chain attacks are expected to multiply by 4 year by year



Supply Chain 4.0

"One clear message is that, as economies move to being built in part on digital foundations, trade, global value chains and digital technology cannot be separated and dealt with as independent trends and forces."

[Michael Spence, Nobel Laureate in Economics]

Supply Chain 4.0 (WTO *def.*)

*The advent of the **Internet of Things** and of the **Industrial IoT** (IIoT), the use of advanced **robotics**, the advent of **5G**, the consolidation of the **Edge-Cloud** for industries and the application of advanced analytics of **big data** in supply chain management, as well as the digitalization of vertical industries is expected to increase the penetration of ICTs to the very core of business and technological processes throughout multiple sectors.*

Place sensors in everything, create networks everywhere, digitalize and automate anything, and analyze everything can significantly improve performance, flexibility and customer satisfaction